Actividad 1.5 — Análisis de noticias de seguridad

Guía de realización y borradores de las dos noticias

Aplicaciones Seguras en la Nube · Máster en Seguridad Informática · Universidad de Jaén · 13 de octubre de 2026

Realizado por Javier Francisco Dibo Gómez

Índice de contenidos

1. Qué pide la actividad

2. Pasos y plazos

2.1 Mensaje de reserva

2.2 Noticias que ya han elegido tus compañeros

2.3 Errores que bajan la nota

3. Noticia 1 (hasta el 15/10): borrador

3.1 Título del mensaje

3.2 Cuerpo del mensaje

3.3 Referencias

4. Noticia 2 (hasta el 29/10): borrador

4.1 Título del mensaje

4.2 Cuerpo del mensaje

4.3 Referencias

Índice de tablas

Tabla 1.1: Elementos obligatorios de cada mensaje del foro

1. Qué pide la actividad

La entrega **no es un PDF**: son **dos mensajes independientes** en el foro «Análisis de noticias de seguridad», uno por noticia. Plazos: 1ª noticia hasta el **15 de octubre**, 2ª hasta el **29 de octubre**. Extensión: **400-500 palabras por noticia**. Las normas generales (título, resumen breve, referencias IEEE citadas en el texto, declaración de uso de IA) también aplican.

Elemento	Qué poner	Dónde mirarlo
Resumen breve	Qué pasó, cuándo, quién lo publica	Boletín del proveedor
Enlace a la fuente original	Boletín oficial + una noticia de prensa	Proveedor / prensa
Proveedor, servicio, software	Producto y versiones afectadas y corregidas	Boletín, registro CVE
Impactos STRIDE	Letra(s) S, T, R, I, D, E justificadas	Tu análisis
CVSS	Oficial con vector; si no hay, estimado y justificado	cve.org / NVD
Vulnerabilidades y CVE	ID CVE y CWE	cve.org
KEV	¿Está en el catálogo de CISA?	cisa.gov KEV
EPSS	Probabilidad y percentil, con fecha	api.first.org
≥ 4 controles CCM v4.1	ID + nombre + cómo habría prevenido o mitigado	Documento CCM–ENS de la asignatura
Referencias IEEE	Numeradas [1], [2]… y citadas en el texto	—
Uso de IA	Herramienta y uso que le has dado (norma 8)	—

Tabla 1.1: Elementos obligatorios de cada mensaje del foro

2. Pasos y plazos

1. **Hoy (13/10): reserva las dos noticias** en el hilo «Avisos de selección de noticias de seguridad, WIP». El profesor lo pide para evitar duplicados. Texto listo para pegar en la sección «Mensaje de reserva».
2. **Antes del 15/10:** revisa el borrador de la noticia 1. **Reescríbelo con tus palabras**, sobre todo la conclusión (la norma 7 penaliza la copia sin reflexión propia). Comprueba los IDs CCM en el documento de equivalencias CCM–ENS de la web de la asignatura: la v4.1 eliminó un control IAM y la numeración cambió (por eso tus compañeros usan IAM-15 para *Authorization Mechanisms*, que en v4.0 era IAM-16).
3. **Publica la noticia 1** como mensaje nuevo en el foro, con el título en formato «CVE-XXXX: descripción», igual que tus compañeros.
4. **Antes del 29/10:** revisa el borrador de la noticia 2, reescribe la conclusión con tus palabras y publícala como mensaje nuevo en el foro.
5. **Extra para nota:** comenta con aportaciones reales 1 o 2 noticias de compañeros. El profesor dice que los comentarios relevantes cuentan en la nota de participación.

2.1 Mensaje de reserva

> Buenas tardes, me gustaría trabajar en las siguientes noticias:
>
> 1 - CVE-2026-105812 y CVE-2026-106032: inyección de código y SSRF en la importación de agentes de Amazon Bedrock AgentCore Starter Toolkit (06/10/2026). Fuente: AWS Security Bulletin 2026-127-AWS https://aws.amazon.com/security/security-bulletins/2026-127-aws/
>
> 2 - AgentCorruption: robo de credenciales y envenenamiento de memoria entre agentes de Amazon Bedrock AgentCore mediante inyección de prompt (Zenity Labs, 10/10/2026). Sin CVE. Fuente: https://cybersecuritynews.com/agentcorruption-attack/

2.2 Noticias que ya han elegido tus compañeros

No elijas ninguna de estas: Storm-3168/JADEPUFFER (Azure), CVE-2025-55241 (Entra ID), CVE-2026-107352 (Athena), Meta Muse, CVE-2026-89332 (Kiro), CVE-2026-81867 (GCP Application Integration), CVE-2026-21589 (Atlassian), CVE-2026-58231 (SAP Commerce Cloud), CVE-2026-90970 (GitLab AI Gateway), CVE-2026-50195 (GKE), CVE-2026-89049 (SSM Agent), CVE-2026-103956 (Loom for AWS), CVE-2026-2270 y CVE-2025-62159 (Kubernetes), CVE-2026-86830 (IAM Identity Center), CVE-2026-104019 (SageMaker), CVE-2026-105811

(QnABot), CVE-2026-87912/87913 (AWS Security Agent), CVE-2026-13762/13763 (AWS WAF), CVE-2025-32444 (vLLM), CVE-2026-33017 (Langflow), CVE-2026-69836 (Entra ID), CVE-2026-63688/63692 (Dell CSM), CVE-2025-23206 (AWS CDK).

2.3 Errores que bajan la nota

- Pasar de 500 palabras. Cuenta solo el cuerpo, no las referencias.
- Poner referencias al final sin citarlas en el texto con [n].
- Dar el CVSS sin vector, o un CVSS estimado sin justificar cada métrica.
- Listar controles CCM sin decir **cómo** habría ayudado cada uno a esta vulnerabilidad concreta.
- Omitir la declaración de uso de IA. La norma 8 la exige y su ausencia puede abrir un expediente (norma 9).
- Escoger algo que no es de nube (móvil, navegador, aplicación local). La nota 9 del enunciado lo excluye.

3. Noticia 1 (hasta el 15/10): borrador

Datos comprobados el 14/10/2026 en el registro oficial CVE, el boletín de AWS, la API EPSS de FIRST y el catálogo KEV de CISA (versión 2026.10.13). El cuerpo tiene menos de 500 palabras.

3.1 Título del mensaje

CVE-2026-105812 y CVE-2026-106032: inyección de código y SSRF en la importación de agentes de Amazon Bedrock AgentCore Starter Toolkit

3.2 Cuerpo del mensaje

Resumen. Dos fallos en el importador de agentes de AgentCore permitían a un usuario de la misma cuenta ejecutar código o leer ficheros en el entorno de quien importa.

El 6 de octubre de 2026 AWS publicó su boletín 2026-127-AWS [1], mencionando las vulnerabilidades encontradas y parcheadas sobre Bedrock AgentCore Starter Toolkit que permitían la ejecución de código remoto arbitrario. Las versiones afectadas son de 0.1.4 a 0.3.13 (corregido en 0.3.14); el paquete está obsoleto y AWS recomienda migrar a «@aws/agentcore» [1], [6].

CVE-2026-105812 (CWE-94, inyección de código) [2]: La gestión inadecuada de la generación de código para importar un agente del toolkit antes de la versión parcheada

0.3.14 permitiría a un actor autenticado ejecutar código arbitrario cuando un usuario importe o ejecute un agente Bedrock, al no escapar los valores de configuración insertados.

CVE-2026-106032 (CWE-918 SSRF y CWE-73) [3]: Una SSRF en el esquema OpenAPI del Toolkit permitiría a un actor autenticado lanzar peticiones arbitrarias y leer archivos locales en el mismo entorno de otro usuario a través de valores de referencia asociados a un grupo de action de Bedrock Agent.

Para solucionarlo es necesario actualizar a la versión 0.3.14 y reimportar cualquier agente importado con una versión previa.

STRIDE. El primer CVE entra en la categoría Tampering, por la alteración del código generado y una Elevation of Privilege por ejecutar código con las credenciales y roles de la víctima. El segundo CVE supone Information Disclosure, por poder acceder a archivos locales privados.

CVSS. AWS asigna al CVE-2026-105812 un CVSS 3.1 de 9,0 (crítico), AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H, y un CVSS 4.0 de 8,8. El cambio de alcance (S:C) refleja que el código salta de la configuración del agente al entorno de otra identidad. El CVE-2026-106032 obtiene 5,7 (medio), AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:N/A:N, al afectar solo a la confidencialidad [2], [3].

KEV y EPSS. Ninguno figura en el catálogo KEV de CISA [5] y el análisis SSVC de CISA indica explotación «none». El EPSS a 14/10/2026 es 0,28 % (percentil 19) y 0,23 % (percentil 13) [4]: riesgo bajo de explotación debido a la necesidad de la cuenta.

Controles CCM v4.1 [7]:

- **AIS-04 Ciclo de vida de desarrollo seguro de aplicaciones:** un generador de código no debe concatenar datos sin escapar; usar codificación segura de literales habría evitado la inyección.
- **TVM-06 Vulnerabilidades en bibliotecas externas:** un inventario de dependencias con alertas habría detectado el paquete obsoleto y forzado la migración.
- **IAM-05 Mínimo privilegio:** restringir quién puede modificar agentes y *action groups* elimina al atacante interno de la cadena.
- **I&S-03 Seguridad de red:** limitar la salida de red del entorno de importación habría frenado el SSRF.

Conclusión. La importación de los agentes suponía un ataque similar a uno de cadena de suministro, donde una importación implicaba un ataque bajo una cuenta supuestamente segura y un actor podría explotar su equipo debido a un error al vetar los datos por parte de la herramienta.

Uso de IA: Claude (Anthropic) para localizar la noticia, recopilar datos oficiales y revisar la redacción.

3.3 Referencias

[1] Amazon Web Services, «CVE-2026-105812 and CVE-2026-106032: Issue with Bedrock AgentCore Starter Toolkit - Import Agent Code Injection and SSRF», AWS Security Bulletin 2026-127-AWS, 6 oct. 2026. [En línea]. Disponible en: https://aws.amazon.com/security/security-bulletins/2026-127-aws/

[2] CVE Program, «CVE-2026-105812», 6 oct. 2026. [En línea]. Disponible en: https://www.cve.org/CVERecord?id=CVE-2026-105812

[3] CVE Program, «CVE-2026-106032», 6 oct. 2026. [En línea]. Disponible en: https://www.cve.org/CVERecord?id=CVE-2026-106032

[4] FIRST, «Exploit Prediction Scoring System (EPSS) API». Consultado: 14 oct. 2026. [En línea]. Disponible en: https://api.first.org/data/v1/epss?cve=CVE-2026-105812,CVE-2026-106032

[5] CISA, «Known Exploited Vulnerabilities Catalog», versión 2026.10.13. [En línea]. Disponible en: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

[6] Let's Data Science, «AWS Security Bulletins Detail Two Patched Amazon Bedrock AgentCore SDK Flaws», oct. 2026. [En línea]. Disponible en: https://letsdatascience.com/news/amazon-bedrock-agentcore-sdk-patches-rce-flaws-09c67772

[7] Cloud Security Alliance, «Cloud Controls Matrix and CAIQ v4.1», 2026. [En línea]. Disponible en: https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4-1

4. Noticia 2 (hasta el 29/10): borrador

Datos comprobados el 28/10/2026 en la publicación original de Zenity Labs, la guía de AgentCore de AWS y la prensa hasta el 22/10. El cuerpo tiene menos de 500 palabras.

4.1 Título del mensaje

AgentCorruption: robo de credenciales y envenenamiento de memoria entre agentes de Amazon Bedrock AgentCore mediante inyección de prompt

4.2 Cuerpo del mensaje

Resumen. Un solo prompt enviado a un agente público de Amazon Bedrock AgentCore permitía robar las credenciales de su rol y tomar el control de todos los agentes de la misma cuenta y región.

Zenity Labs lo publicó el 8 de octubre de 2026 [1], y la prensa lo recogió el 10 [2]. Afecta a AgentCore Runtime, Memory e Identity, Secrets Manager y ECR. No es un fallo de código: es una red poco aislada más un rol por defecto con demasiados permisos.

Cadena de ataque [1]:

1. El prompt ordena a una herramienta web del agente consultar el servicio de metadatos, que devuelve las credenciales del rol de ejecución (SSRF mediante inyección de prompt).
2. `DescribeLogGroups` revela los IDs de los demás agentes, y sus imágenes se descargan de ECR.
3. `InvokeAgentRuntime` y `ListEvents` invocan otros agentes y leen conversaciones privadas.
4. `CreateEvent` planta memorias falsas que persisten en sesiones futuras.
5. `GetSecretValue` y `GetResourceApiKey` exponen las credenciales de las herramientas de negocio.

Respuesta de AWS. AWS niega que sea una vulnerabilidad: que el agente lea las credenciales de su rol es «documentado y esperado» [1], [3]. Aun así, impuso IMDSv2 en febrero y recortó el rol por defecto el 29 de septiembre. Los roles ya desplegados conservan la política antigua [4]: revisarlos es tarea del cliente.

STRIDE. *Spoofing* (el atacante actúa como el agente), *Tampering* (memorias envenenadas), *Information Disclosure* (secretos, conversaciones e imágenes) y *Elevation of Privilege* (de usuario anónimo de un chat a credenciales IAM sobre la región).

CVE, KEV y EPSS. No tiene CVE, porque AWS no lo reconoce como vulnerabilidad; por tanto no hay KEV ni EPSS. No consta explotación real [4].

CVSS estimado. 8,7 (alto), `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N` [5]. AV:N, PR:N y UI:N: el prompt llega por red a un agente público, sin cuenta ni víctima. AC:H: requiere una herramienta de red y el rol por defecto. S:C: salta a otros agentes y a Secrets Manager. C:H por los secretos, I:H por las memorias, A:N sin impacto demostrado en la disponibilidad.

Controles CCM v4.1 [6]:

- **IAM-05 Mínimo privilegio:** un rol por agente, limitado a sus propios recursos, habría dejado las credenciales robadas sin alcance lateral.
- **I&S-03 Seguridad de red:** bloquear el endpoint de metadatos y la salida de red innecesaria habría cortado el primer paso.
- **I&S-06 Segmentación y segregación:** separar los agentes públicos de los internos limita el radio de impacto.
- **LOG-03 Monitorización y alertas de seguridad:** una alerta en CloudTrail por el uso de las credenciales del rol desde fuera de AWS habría detectado el robo.

Conclusión. Un agente con herramientas es un empleado con credenciales que obedece a cualquiera que le escriba. En el modelo de responsabilidad compartida el rol es del cliente, y un valor por defecto amplio convierte un prompt en una intrusión en toda la región.

Uso de IA: Claude (Anthropic) para localizar las fuentes, recopilar los datos y revisar la redacción.

4.3 Referencias

[1] T. Ishay Sharbat y L. Salameh, «AgentCorruption: How a Single Prompt Collapsed the Entire Cloud Security Model», Zenity Labs, 8 oct. 2026. [En línea]. Disponible en: https://labs.zenity.io/post/agentcorruption-how-a-single-prompt-collapsed-the-entire-cloud-security-model

[2] G. Baran, «One Prompt Could Hijack AWS AI Agents and Steal Cloud Credentials», Cyber Security News, 10 oct. 2026. [En línea]. Disponible en: https://cybersecuritynews.com/agentcorruption-attack/

[3] Amazon Web Services, «Understanding credentials management in Amazon Bedrock AgentCore», Amazon Bedrock AgentCore Developer Guide. Consultado: 28 oct. 2026. [En línea]. Disponible en: https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/security-credentials-management.html

[4] O. Jones, «AgentCorruption: AWS Tightened AgentCore's Default Role, Not Yours», Secjuice, 22 oct. 2026. [En línea]. Disponible en: https://secjuice.com/agentcorruption-aws-tightened-agentcores-default-role-not-yours/

[5] FIRST, «Common Vulnerability Scoring System v3.1 Calculator». Consultado: 28 oct. 2026. [En línea]. Disponible en: https://www.first.org/cvss/calculator/3.1#CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

[6] Cloud Security Alliance, «Cloud Controls Matrix and CAIQ v4.1», 2026. [En línea]. Disponible en: https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4-1